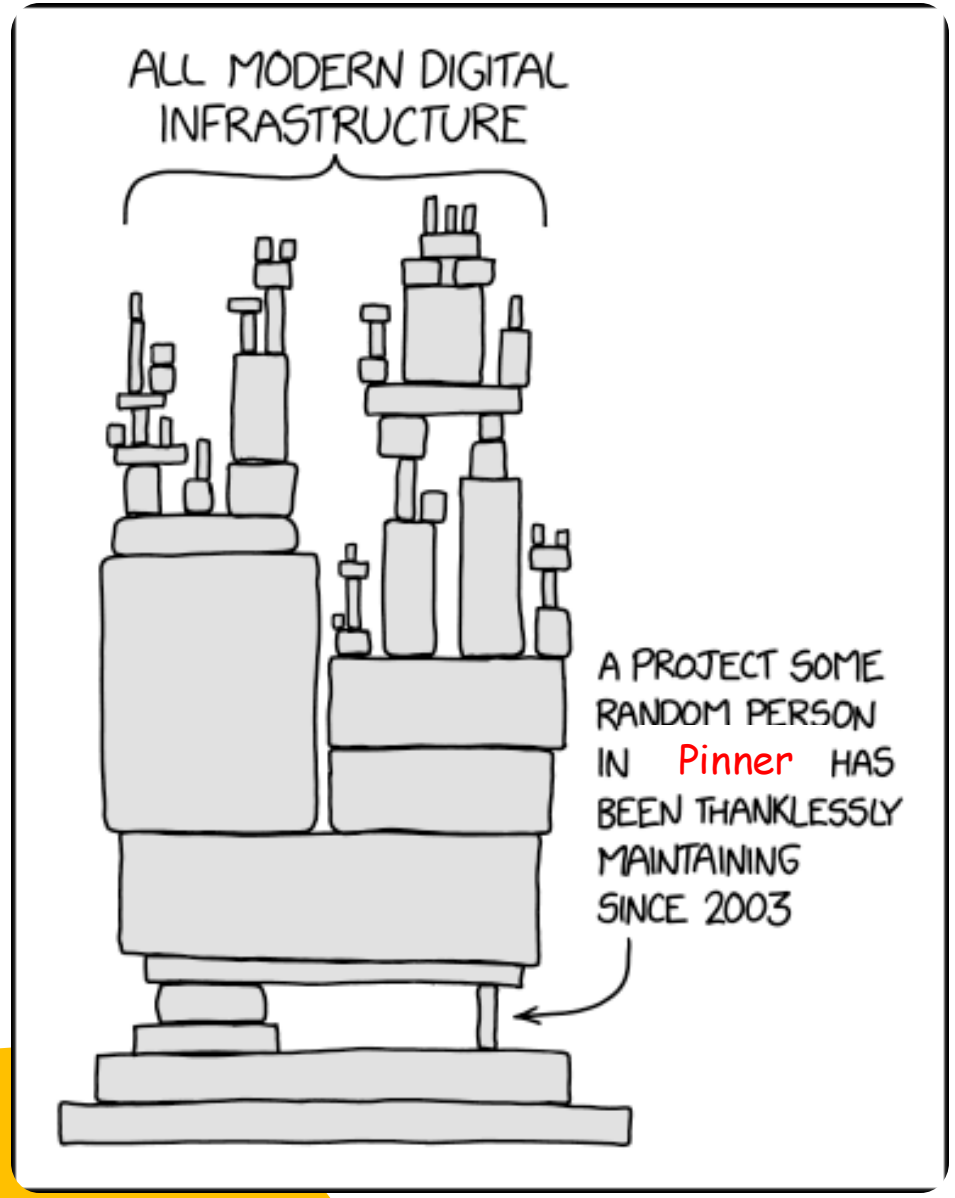
A rising tide lifts all ships

Cyber security culture, competence and community

Who am I?

@timb_machine



Goal of this session

- Folklore and fairytales
- Reflect on things that often remain unsaid
- Make you think

Check out https://github.com/CiscoCXSecurity and @portcullislabs for some of the ways that Cisco's professional service teams give back.

Standards and frameworks

Secure by design?

Preparation is important

- Get to know the NIST CSF (https://www.nist.gov/cyberframework)
  - Identify – what do you have, what should you protect? (https://www.cisecurity.org/)
  - Protect – hardening? (https://d3fend.mitre.org/)
  - Detect – who is doing what and why? (https://github.com/rabobank-cdc/DeTTECT)
  - Respond – preparation is key!
  - Recover – what does a business continuity or distaster recovery plan look like?
- Don’t wait too long to have a plan for detection, response and recovery
  - Logging and auditing are only useful, if you use them
  - Backups need to be tested

Cisco Confidential

The two bears

- Cyber security means outrunning both
  - Regulators
    - Fines
  - Threats
    - Confidentiality
    - Integrity
    - Availabilty

Cisco Confidential

Compliance

- No-one is compliant at the time of breach
  - PCI DSS (https://www.pcisecuritystandards.org/)
  - IEC 62443 (https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards)
  - ISO 27001 (https://www.iso.org/standard/27001)
  - GDPR (https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/)

Cisco Confidential

Working with regulators

- Regulators can have a huge impact on how an organisation prioritises cyber security
  - Current focus of many regulators is resilience
    - EU's NIS2 directive (https://www.europarl.europa.eu/thinktank/en/document/EPRS_BRI(2021)689333)
    - UK's TSA CoP (https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/1120531/E02781980_Telecommunications_Security_CoP_Accessible.pdf)
- Just some of the new regulatory frameworks from the EU and UK which will impact how we work
  - Keep an eye on Estonia, Singapore, India and the USA

Cisco Confidential

How governments work

- UK approach has moved from strict definition of policies to encouraging adoption of principles and practices
- UK regulators often function as market makers
  - Current “hard” problems (https://www.ncsc.gov.uk/collection/problem-book)
- UK regulatory touch points
  - Cyber Assessment Framework (https://www.ncsc.gov.uk/collection/caf)
    - NCSC’s principles and how to apply them
  - Assurance
    - Cyber Essentials (https://www.ncsc.gov.uk/section/products-services/cyber-essentials)
    - CHECK (https://www.ncsc.gov.uk/information/check-penetration-testing) etc
  - Information exchanges
    - CISP (https://www.ncsc.gov.uk/cisp/home)
  - Incident support

Cisco Confidential

What is an RFC and why you should care

- Request for comments
  - Common approach to community standards (https://www.ietf.org/proceedings/62/slides/editor-0.pdf)
  - Championed by the IETF (https://www.ietf.org/)
  - A great place to find security challenges
    - MUST vs SHOULD
    - Revisions
    - Just search for the word security ☺

Cisco Confidential

Culture

Effective communication to build consensus

Contact with reality

- No standard survives contact with reality
  - Principles over policies
    - E.g. cryptography
  - Listen when people say no
    - Ask questions
    - Look for consensus

Cisco Confidential

The value of being cross-domain

- Nothing wrong with being early in career in cyber security
  - But learn your customers' businesses too
    - Wardley mapping (https://medium.com/wardleymaps) is an interesting tool to understand as-is vs to-be
      - Value chain
      - User need
      - Evolution
        - Genesis
        - Custom
        - Product
        - Commodity
- Every cyber security specialist brings themselves to their role
  - Be apocryphal
  - Leverage empathy

Cisco Confidential

Abstraction and metaphors

- Enterprise architectures
  - SABSA (https://sabsa.org/)
  - ITIL (https://en.wikipedia.org/wiki/ITIL)
- Threat models
  - STRIDE (https://learn.microsoft.com/en-us/previous-versions/commerce-server/ee823878(v=cs.20))
  - ATT&CK (https://attack.mitre.org/)
- Risk
  - FAIR (https://www.fairinstitute.org/)
- All models are wrong, some are useful

Cisco Confidential

Depth vs breadth

- As cyber security has matured, disciplines have specialised
  - Means you can find people who are brilliant in one area and completely naïve in others
- Value in being a generalist
  - A large part of my role is translation between layers and between domains

Cisco Confidential

Your threat model may not be your adversary's threat model

- Threat models (https://shostack.org/books/threat-modeling-book) describe bad outcomes which can be thought of as misuse cases
  - Technical vulnerabilities do not threats necessarily make
    - Rogue wifi
    - Malicious USB memory sticks
  - Cures may itself introduce new threats
    - Burner phones
  - Sociological factors need to be considered
    - Young people
    - Those with special educational needs
  - No-one intentionally clicks on malicious links

Cisco Confidential

Value of information systems is the data

- Technical vulnerabilities are fun
  - But really what an attacker wants is data
    - If they can steal it or they can change it, then they win
- There may be more than one way to achieve this end…

Cisco Confidential

Unless it’s the availability of the data

- If there’s a physical component to a system, availability probably matters
  - Information systems are often used to scale human capability over a wide area
  - If physical attacks are in scope, all bets are off
- If they can limit the victims access to their own data, then they win
  - Again, there may be multiple ways to achieve this

Cisco Confidential

CVSS is not a shoe size

- Scoring vulnerabilities with CVSS is relatively easy (https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator)
  - Scores don't reflect risk
    - Environment characteristics
    - Temporal characteristics
  - They do provide a quick way to understand how a vulnerability might be used
    - Think access vector, authentication etc
    - Libraries are hard, where are they used?
- RAG isn't much better (I'd argue worse)… bring your own biases
  - If you want to learn risk, look at things like FAIR

Cisco Confidential

To change the world, you need data

- You cannot change what you cannot measure
  - The temptation to produce a beautiful Word or PowerPoint document is fine
    - But to teach others, you need to be able to show them patterns
- Lots of freely available cyber security related data:
  - CVEs (https://cve.mitre.org/cve/search_cve_list.html)
  - CWEs (https://cwe.mitre.org/)
  - Breach data (https://www.verizon.com/business/en-gb/resources/reports/dbir/)
  - Networks intelligence (https://viz.greynoise.io/ and https://www.shodan.io/)
  - Malware intelligence (https://www.virustotal.com/ and https://bazaar.abuse.ch/)
  - Malicious web sites (https://any.run/)

Cisco Confidential

Patching is hard but it only gets harder the less you do it

- Prioritisation
  - CISA's Known Exploited Vulnerabilities Catalogue (https://www.cisa.gov/known-exploited-vulnerabilities-catalog)
  - FIRST's Exploit Prediction Scoring System (https://www.first.org/epss/)
  - But…
    - Muscle memory
      - If the last time you applied a patch was 12 months ago, a lot will have changed

Cisco Confidential

Gameplaying

- Think dungeons and dragons and top trumps
  - Roll a die to find out what happened next
- Allows us to explore scenarios where recreation is
  - Dangerous
  - Costly
  - Unpredictable
- Tests people and processes
  - Bad Things Daily (https://twitter.com/badthingsdaily)
  - Backdoors and Breaches (https://www.blackhillsinfosec.com/projects/backdoorsandbreaches/)
  - Exercise in a Box (https://www.ncsc.gov.uk/information/exercise-in-a-box)
- A good way to explore alternate endings
  - Root cause analysis
  - Lessons learnt

Cisco Confidential

Security must support the business

- Remembering this is critical to showing value
  - What are your business imperatives?
    - Make money, reduce costs
  - Where and how will confidentiality, integrity and availability concerns impact this?
    - Why should your leadership care?
    - What costs are you hoping to avoid?
      - Who does this benefit?

Cisco Confidential

Competence

Building confidence in yourself and others

Understand law and ethical implications

- Building trust means that people need to know where you stand
  - What's right isn't always what's legal and what's legal isn't always right
  - Things to consider
    - Authority to act
    - Impact on 3rd parties
    - Impact of doing nothing
    - Side effects
- Examples of legal frameworks
  - Espionage – Official Secrets Act (https://www.legislation.gov.uk/ukpga/1989/6/contents)
  - Criminal – Computer Misuse Act (https://www.legislation.gov.uk/ukpga/1990/18/contents)
  - Data privacy – Data Protection Act (https://www.gov.uk/data-protection)
  - Human rights – Human Rights Act (https://www.legislation.gov.uk/ukpga/1998/42/contents)
  - …
- If in doubt, speak to a lawyer

Cisco Confidential

Professionalisation and certifications

- UK values schemes such as CREST (https://https://www.crest-approved.org/) and other similar schemes for CNI purposes
  - Introductory level for all consultants (https://www.crest-approved.org/skills-certifications-careers/crest-practitioner-security-analyst/)
  - Streams for architecture, IR, pen testing, TI and red teaming as well to demonstrate organizational fitness (https://www.crest-approved.org/skills-certifications-careers/crest-certifications/)
- Beyond that, it's more about developing your own skills
  - There are many bodies that offer training and certification
  - Critical to consider why you need the skill
- Approaches
  - Technologies and architectures
    - You won't go far wrong understanding cloud, be that AWS (https://aws.amazon.com/training/learn-about/security/), GCP (https://cloud.google.com/security), Azure (https://learn.microsoft.com/en-us/azure/security/fundamentals/overview) etc
  - Service lines
    - Some are more attractive than others

Cisco Confidential

Red vs Blue

- The colours don’t really matter
  - Red team
    - Tests defences
    - Tries to break in
    - Pen testers etc
  - Blue team
    - Builds defences
    - Tries to detect, respond, recover
    - SOC teams, incident response etc
- Some will talk about other colours
  - G(overnance), R(isk) and C(ompliance), architects, system and network engineers, developers, product owners, etc

Cisco Confidential

Vulnerability disclosure

- Definitions
  - 0-day
    - Definitions for this vary, but realistically, it refers to situations where the victim vendor or user group is blindsided
  - Full disclosure
    - Where all of the details are shared
  - Forced disclosure
    - Where vulnerabilities are disclosed without direct vendor co-operation, generally due to lack of response
  - Co-ordinated disclosure
    - Where vulnerabilities are disclosed in co-operation with the vendor, generally with less details
- Good practice
  - There is actually an ISO standard (https://www.iso.org/standard/45170.html)
  - In general
    - Give vendors up to 90 days to respond
    - Don't blame, don't threaten
    - Check out https://disclose.io/ for more advice

Cisco Confidential

Traffic light protocol

- Used to label threat intelligence
  - Sensitivity vs useability
- Check out https://www.cisa.gov/news-events/news/traffic-light-protocol-tlp-definitions-and-usage for a more formal definition
  - RED – not for disclosure, recipient only
  - AMBER(-STRICT) – limited to own organization, need to know
    - Non-STRICT typically means you tell your downstream customers
  - GREEN – community
  - WHITE (or CLEAR) – public, disclosure isn't limited

Cisco Confidential

Technical skills that you'll benefit from

- Basic TCP/IP
  - IPs, ports and sockets, DNS and routing
    - (It's always DNS, except when it's routing)
- Everything is web based these days
  - Learn how web browsers work (https://www.mozilla.org/en-GB/firefox/browsers/what-is-a-browser/)
    - HTML
    - HTTP
  - Learn common types of web–based vulnerabilities (https://owasp.org/www-project-top-ten/)
- Learn Python (https://python.org/), learn PowerShell, learn Excel macros
  - Even if you're just managing data, if you have to do it twice, scripting will make the second time less painful

Cisco Confidential

Being a hero is fine, but you will tire

- Tie what you're doing back to frameworks and regulations
  - Build repeatable methodologies
  - Question banks for workshops etc
  - Decide how you want to structure your data
  - What does your business or user need to measure
- Teach and mentor others
  - Scale your passion
  - How do you turn your idea into a product: https://www.gov.uk/service-manual/the-team/what-each-role-does-in-service-team

Cisco Confidential

Know your own value

- In general, I don’t charge for speaking etc
  - That doesn’t mean you shouldn’t
    - An off-the-cuff example, £3k for a 1-hour slot with a high-profile speaker
- Conferences will usually be up front about what they can do to reimburse you
  - Expect commercial conferences to support travel and accommodation at the least
  - Non-profit events may still be able to support you
    - This is likely determined by the sponsorship they have
    - As well as the governance model
- Build your brand…
  - Maybe it’s still great publicity but…

Cisco Confidential

Learn from failure

- Fails are still worth sharing
  - We all learnt about pain, the first time we caught our flesh on something hot or sharp
- If you're presenting to others, think about
  - Stuff that you've built that can be reused
  - Why didn't something work
  - What would you do differently next time
  - How can others build on this

Cisco Confidential

Mentoring

- Don’t be afraid to ask for help
  - Some will actively offer, but even if they don’t…
  - Everyone started somewhere
  - Places to look
    - I found my first mentors by looking for researchers I admired who posted to oss-security
- It’s okay to seek out alternate opinions
  - It doesn’t have to be a 1:1 relationship
- Regular syncs can be helpful
  - But so can one off sessions
- Give back when you’re ready

Cisco Confidential

Community

Where to next?

A good community is a place for everyone

- You should be safe to explore diverse approaches to complex problems
  - I can’t promise every cyber security community will be perfect but the best ones will try to improve
    - Keep an eye out for communities with a code of conduct (https://www.contributor-covenant.org/ etc)
  - Remember about the Paradox of Tolerance (https://en.wikipedia.org/wiki/Paradox_of_tolerance)

Cisco Confidential

Social media?

- None of them are perfect
  - People
    - Twitter
    - LinkedIn
    - Fediverse (https://infosec.exchange/, https://defcon.social/)
  - Communities
    - Slack
    - Discord
- But they all offer value
  - Find people you trust, follow them
  - Follow tags that interest you
  - Just watch out for the intolerance, disinformation
  - Actively block and mute
  - Don’t forget to enable MFA

Cisco Confidential

Conferences?

- Many, many conferences now exist
  - For almost every type of person
  - For almost every security interest
  - For almost every budget
- Some personal favourites (least to most commercial)
  - OWASP chapters (https://meetup.com/pro/owasp)
  - Def Con chapters (https://forum.defcon.org/social-groups)
  - Security BSides (https://www.securitybsides.com/)
  - ATT&CK Community (https://www.attack-community.org/)
  - Black Hat Europe (https://blackhat.com/)
  - CRESTCon (https://www.crestcon.org/)

Cisco Confidential

Peer review early, peer review often

- Peer reviews encourage an iterative approach
- A second opinion never hurts
  - Great when you get stuck
  - Helps you minimize the time you spend on something
  - It may expand your understanding of the problem
  - Gives you examples to consider in your solution
  - Helps you to think about how you explain your solution
  - Can point you at other related topics
- This session itself had input from a variety of sources, within and external to Cisco
  - (thanks Offensive Summit team and Andrew, David, Daria, Dario, Dean, Jamie, Nick, Saskia, Shammas, Vitor, et al)

Cisco Confidential

Citations please

- We all stand on the shoulders of others
- Effective citing can mean
  - Due diligence
  - Learning new approaches
  - Sharing existing approaches
  - Reflecting deeper knowledge
  - Giving fair credit
  - Not wasting time

Cisco Confidential

CTFs?

- CTFs are Capture The Flag (https://ctftime.org/) competitions
  - Learn a new skill
  - Solve a challenge to score points
  - Compete with other attendees for rank
  - Potentially win prizes
- Challenges tend to vary from event to event but some common tasks may include
  - Trivia
  - Treasure hunts
  - Solving riddles
  - Exploiting vulnerabilities
  - Analysing files
  - Analysing network traffic
  - Reverse engineering binaries
  - Lock picking

YXNrIG1lIGFib3V0IHNwYWNlIGludmFkZXJzCg==

Cisco Confidential

Hallwaycon?

- Hallwaycon is defined at the time spent at conferences where you're not directly attending sessions
  - Where you see your friends and colleagues and make new connections
  - After a while, it's arguable that hallwaycon can be seen as more valuable than the talks themselves
    - May only be 1-2 sessions that interest you
    - Much is recorded these days
  - More than a few companies, projects and jobs have happened because of hallwaycon
    - Use your common sense, but don't be afraid to introduce yourself to new people

Cisco Confidential

Open source?

- We all rely on open source (https://opensource.org/)
  - Whether that's
    - Building infrastructure
    - Developing software
    - Performing security testing
    - Monitoring services
    - Sending/receiving email
    - Clicking links in the morning over breakfast
  - As with other aspects, find a way to give back
- Check out http://github.com/timb-machine-mirrors for some awesome security projects (NOT MINE)

Cisco Confidential

Thanks

twadhwab@cisco.com / @timb_machine

Cisco Confidential